# Éléments pour le délégué à la protection des données — registre des traitements et analyse d'impact

*Proposition à adapter par le délégué à la protection des données (DPO, référent RGPD) de l'établissement. Ce document ne constitue pas un avis juridique ; les rubriques marquées « à valider » relèvent de la décision du responsable de traitement.*

Tessera Santé est une plateforme : un **socle commun** (comptes, droits, chiffrement, stockage, journal) et des **modules** ouverts service par service. Chaque module poursuit des finalités propres : **une fiche du registre des traitements est proposée par module** (section 1), le socle étant décrit avec chacune. Un module qui n'est ouvert dans aucun service n'est pas mis en œuvre et n'a pas à figurer au registre.

## 1. Fiches du registre des traitements (propositions)

### Rubriques communes aux traitements

| Rubrique | Contenu proposé |
|---|---|
| Responsable de traitement | L'établissement, représenté par son directeur |
| Données des professionnels | Nom, identifiant, rôles, services affectés ; horodatage et auteur de chaque saisie |
| Transferts hors UE | Aucun. Les données ne quittent pas l'infrastructure de l'établissement. Si l'application est servie par GitHub Pages (phase pilote), seul le code est fourni par ce service, sans aucune donnée |
| Sous-traitants | Aucun pour les données (pas d'hébergeur externe ; stockage sur un partage réseau de l'établissement) |
| Mesures de sécurité | Chiffrement AES-256 sur le poste ; **une clé par module**, remise aux seuls agents qui y ont droit, renouvelée au retrait d'un droit ; coffre des clés signé par l'administrateur et vérifié par chaque agent ; comptes nominatifs, rôles, services affectés ; verrouillage après inactivité ; journal en ajout seul, chaîné ; droits NTFS sur le dossier ; sauvegardes ; aucun flux sortant (voir la fiche technique) |
| Droits des personnes | Accès : export des données d'un patient, tous modules confondus (onglet Patients, cadre ou administrateur, tracé au journal ; les noms des professionnels n'y figurent pas). Rectification : corrections tracées. Opposition et effacement : limités par les obligations légales propres à chaque traitement (à valider) |
| Durée de conservation (à valider) | À fixer par l'établissement pour chaque traitement. L'outil conserve tout l'historique (journal jamais modifié) et signale les patients dont les données dépassent la durée choisie, à traiter selon la procédure validée par le délégué à la protection des données ; aucune suppression automatique |

## Traitement 1 — Fiche patient commune (module Patients)

| Rubrique | Contenu proposé |
|---|---|
| Nom du traitement | Fiche administrative commune des patients des services utilisant Tessera Santé |
| Finalités | Identifier de façon fiable les patients suivis par les autres modules ; tenir à jour leur séjour (unité, chambre), les médecins et référents soignants ; éviter les doublons |
| Base légale (à valider) | Article 6.1.e du RGPD (mission d'intérêt public) ; données de santé : article 9.2.h (prise en charge sanitaire) |
| Personnes concernées | Patients hospitalisés dans les services concernés |
| Données | Identité (nom, prénom, nom de naissance, sexe, date de naissance, identifiant permanent du patient ou IPP), séjours (numéro de séjour ou IEP, dates d'entrée et de sortie, unité, chambre et lit), service, médecins de 1re et 2e ligne, référents soignants, mesure de protection juridique (oui ou type) ; en psychiatrie, mode d'hospitalisation et son historique, situation de détention. **Aucune donnée clinique** |
| Source | Saisie par les agents habilités ; import d'une liste exportée du dossier patient informatisé (DPI), lue sur le poste, jamais copiée sur le partage |
| Destinataires | Agents habilités des services concernés ; les autres modules lisent la fiche (lecture seule) pour leurs propres finalités |

## Traitement 2 — Suivi des mesures d'isolement et de contention (module Isocont)

| Rubrique | Contenu proposé |
|---|---|
| Nom du traitement | Suivi des mesures d'isolement et de contention en psychiatrie |
| Finalités | 1. Suivre la durée des mesures et leur cumul ; 2. Anticiper et tracer l'information et la saisine du juge des libertés et de la détention (JLD) ; 3. Tracer l'information des tiers et les professionnels chargés de la surveillance ; 4. Tenir le registre prévu à l'article L. 3222-5-1 du code de la santé publique ; 5. Produire le rapport annuel et des statistiques anonymisées |
| Base légale (à valider) | Article 6.1.c du RGPD (obligation légale : registre et contrôle du juge, art. L. 3222-5-1 du code de la santé publique) et 6.1.e (mission d'intérêt public) ; données de santé : article 9.2.h et 9.2.i (intérêt public dans le domaine de la santé publique) |
| Personnes concernées | Patients faisant l'objet d'une mesure ; tiers informés (qualité seulement) ; professionnels (psychiatres décisionnaires, soignants chargés de la surveillance) |
| Données | Données de la fiche patient (lues, non recopiées) ; mesures (type, lieu, dates et heures, psychiatre, pauses), information des tiers (qualité du tiers, résultat), communications avec le JLD, professionnels chargés de la surveillance par poste |
| Destinataires | Agents habilités ; registre (IPP, âge, psychiatre, soignants) : instances prévues par la loi (commission départementale des soins psychiatriques ou CDSP, Contrôleur général des lieux de privation de liberté ou CGLPL, parlementaires) ; demandeurs au titre du code des relations entre le public et l'administration (CRPA, avis de la Commission d'accès aux documents administratifs ou CADA) : version occultée seulement ; JLD : décompte joint aux communications |

### Traitement 3 — Agenda du service (module Agenda)

| Rubrique | Contenu proposé |
|---|---|
| Nom du traitement | Organisation du service : agenda, tâches, absences, alertes |
| Finalités | Planifier les accompagnements de patients, activités thérapeutiques, réunions et sorties ; préparer les sorties (check-lists) ; organiser les tâches du service ; connaître les absences des professionnels ; signaler les patients à voir et les échéances à venir |
| Base légale (à valider) | Article 6.1.e du RGPD (mission d'intérêt public) ; données de santé : article 9.2.h ; pour les absences des agents : article 6.1.b ou 6.1.e (gestion du personnel, à valider) |
| Personnes concernées | Patients des services ; professionnels (prévus sur un élément, affectés à une tâche, absents) |
| Données | Patients : désignation selon le réglage de l'établissement (**initiales par défaut**, IPP, nom complet ou « patient »), participation à un accompagnement ou une activité (intitulé, date, lieu), check-lists d'organisation, alertes d'organisation (type, date limite). Professionnels : présence prévue, tâches faites (nom et heure), absences (dates ; **motif facultatif, jamais médical**). **Aucune donnée clinique** : le contenu des prises en charge reste dans le dossier du patient |
| Lecture d'autres modules | Échéances JLD calculées à la volée par le module Isocont, affichées aux seuls agents qui ont l'accès aux envois au JLD ; aucune copie |
| Destinataires | Agents habilités des services concernés ; un élément d'un autre service qui concerne un patient hospitalisé dans le service y est visible, limité à ce patient. « Mon agenda » : vue personnelle dans l'outil, sans export ni synchronisation vers un autre agenda |

### Traitement 4 — Véhicules de l'établissement (module Véhicules)

| Rubrique | Contenu proposé |
|---|---|
| Nom du traitement | Gestion et réservation des véhicules de service |
| Finalités | Connaître le parc des véhicules et leur service d'affectation, organiser leur prêt entre services, les réserver (directement ou pour un événement de l'agenda), suivre les tâches qui les concernent (plein, nettoyage, voyant, entretien) |
| Base légale (à valider) | Article 6.1.e du RGPD (mission d'intérêt public) ou 6.1.b (gestion du personnel et des moyens), à valider |
| Personnes concernées | Professionnels (auteur d'une réservation ou d'un signalement). **Aucun patient** : une réservation faite depuis l'agenda porte la catégorie de l'événement (ex. « Activité »), jamais l'identité du patient |
| Données | Véhicules (caractéristiques, immatriculation, stationnement, informations ajoutées par l'administrateur) ; réservations et pré-réservations (véhicule, horaires, service, agent, motif court ; pré-réservation remplacée : par qui, quand) ; signalements (type, précision, auteur, date, « fait ») |
| Lecture d'autres modules | L'agenda lit à la volée la disponibilité des véhicules du service ; aucune copie |

| Rubrique | Contenu proposé |
|---|---|
| Destinataires | Agents habilités des services où le module est activé ; un service emprunteur voit le véhicule prêté ou mis à disposition |

### Traitement 5 — Suivi médical (module Suivi médical) et liste commune des médecins

| Rubrique | Contenu proposé |
|---|---|
| Nom du traitement | Organisation du suivi médical des patients hospitalisés et des présences médicales |
| Finalités | Connaître les présences, absences et gardes des médecins par service ; s'assurer que chaque patient a ses médecins de 1re et 2e ligne et qu'il est vu et que son contrat de soins est réévalué dans les délais ; imprimer les tableaux du service |
| Base légale (à valider) | Article 6.1.e du RGPD (mission d'intérêt public) ; données concernant la santé : article 9.2.h (organisation des soins), à valider |
| Personnes concernées | Patients hospitalisés ; médecins (y compris intérimaires, sans compte Tessera) ; professionnels auteurs des saisies |
| Données | Patients : identité affichée de la fiche commune, chambre, jour d'hospitalisation, médecins de 1re et 2e ligne, **dates** des entretiens médicaux et des réévaluations du contrat de soins (aucun contenu) ; médecins : nom, anciens noms, fonction, services, statut, période de présence des intérimaires, présences, absences (motif facultatif) et gardes |
| Lecture d'autres modules | Fiche patient (module Patients) lue à la volée ; la liste des patients et l'agenda lisent à la volée les dates et les alertes du Suivi médical ; aucune copie |
| Destinataires | Agents habilités des services où le module est activé ; liste des médecins visible de tous les modules qui la proposent |
| Impressions | Mise en page dédiée avec mention « Document confidentiel — données personnelles de santé » ; nom de l'auteur et date d'impression sur la feuille |

### Traitement 6 — Vue d'ensemble (module Vue d'ensemble) et données ajoutées

| Rubrique | Contenu proposé |
|---|---|
| Nom du traitement | Tableaux de suivi partagés du service (vue d'ensemble, feuille du staff) |
| Finalités | Donner à l'équipe une vue d'ensemble de l'organisation des soins (médecins et référents, entretiens et contrats de soins, sortie prévisionnelle, démarches, check-lists d'entrée…), préparer et garder la feuille du staff, connaître les places disponibles |
| Base légale (à valider) | Article 6.1.e du RGPD (mission d'intérêt public) ; données concernant la santé : article 9.2.h (organisation des soins), à valider |
| Personnes concernées | Patients hospitalisés ; médecins ; professionnels (auteurs des saisies, agents des vues « équipe ») ; le cas échéant, **tiers** (ex. personne à prévenir) selon les données ajoutées par l'établissement |

| Rubrique | Contenu proposé |
|---|---|
| Données | Données de la fiche commune et des autres modules lues à la volée ; **données ajoutées** par l'établissement ou le cadre (chacune à décrire ici : nom, type, services, rôles qui la voient et la modifient, protection) ; **instantanés** (feuille close : valeurs affichées, auteur, date ; annotations) ; capacité d'accueil des services (sans donnée de patient) |
| Données concernant des tiers | Donnée marquée « information concernant un tiers » : exclue de l'export remis au patient (droit d'accès), à faire confirmer par le délégué à la protection des données |
| Données cliniques | Exclues par principe ; option « donnée clinique » activée par l'administrateur seul, donnée par donnée, après avis du délégué à la protection des données, avec clé propre et durée de conservation |
| Lecture d'autres modules | Fiche patient, Suivi médical, Isolement et contention, Agenda lus à la volée ; une case modifiée l'est dans le module propriétaire de la donnée ; aucune copie hors des instantanés |
| Destinataires | Rôles réglés pour chaque vue, chaque colonne et chaque donnée ajoutée ; une donnée à clé propre n'est déchiffrable que par les rôles cochés |
| Durée de conservation | Données ajoutées : comme la fiche patient ; instantanés : durée réglée par l'administrateur (*Instantanés*), à fixer avec le délégué à la protection des données |
| Impressions | En couleur ou en noir et blanc, avec la mention « Document confidentiel — données personnelles de santé » |

## 2. Analyse d'impact (AIPD)

La liste de la CNIL des traitements pour lesquels une analyse d'impact est requise comprend les « traitements de données de santé mis en œuvre par les établissements de santé [...] pour la prise en charge des personnes ». Le traitement 2 porte en outre sur des personnes vulnérables, souvent hospitalisées sans leur consentement. **Une analyse d'impact paraît donc requise**, au moins pour les traitements 1 et 2 ; elle peut couvrir la plateforme entière, avec une partie par module. Elle peut être conduite avec l'outil PIA de la CNIL ; les éléments ci-dessous en préparent la partie « risques ».

### Risques et mesures

| Événement redouté | Sources possibles | Mesures existantes | Gravité / vraisemblance (à évaluer) |
|---|---|---|---|
| **Accès illégitime** aux données | Copie du dossier, poste laissé ouvert, agent hors de son périmètre | Chiffrement ; **un droit = une clé** : un agent sans rôle dans un module n'en détient pas la clé et ne peut pas en lire les données, même avec une copie du dossier ; au retrait d'un droit, nouvelle clé pour les saisies suivantes ; mots de passe ou clés matérielles ; verrouillage automatique ; services affectés par compte (cloisonnement entre services d'un même module par l'interface) ; journal limité selon le rôle ; droits NTFS ; journal nominatif | |

| Événement redouté | Sources possibles | Mesures existantes | Gravité / vraisemblance (à évaluer) |
|---|---|---|---|
| **Modification non désirée** | Erreur de saisie, saisies concurrentes, manipulation | Journal en ajout seul ; corrections et annulations tracées avec motif ; détection des conflits ; chiffrement authentifié (un fichier modifié est rejeté) ; coffre attesté (une modification des comptes ou des clés hors de l'outil est détectée par chaque agent) | |
| **Usurpation après compromission** | Mot de passe d'administrateur, code de secours ou copie du coffre tombés entre de mauvaises mains | « Tout renouveler » : nouvelles clés, nouveau code de secours, nouvelles clés personnelles, mots de passe provisoires (procédure du document 04) | |
| **Exports en clair** (PDF, CSV) | Décomptes et registres nominatifs copiés hors du réseau | Enregistrement dans le dossier des exports du partage (mêmes droits que les données), tracé au journal ; durée de conservation réglable et purge tracée | |
| **Disparition** des données | Suppression de fichiers, panne, rançongiciel, coffre abîmé, perte des moyens de déverrouillage | Sauvegardes du partage ; historique vérifié du coffre ; copie du coffre sous scellé avec le code de secours ; copie de sauvegarde complète ; contrôle d'intégrité de chaque journal à la connexion et toutes les 15 minutes, réparation, quarantaine et prise d'acte tracée ; deux clés d'administration ; procédure dégradée papier | |

### Points d'attention pour l'analyse

- Le contrôle des droits est fait par l'application sur le poste, sans serveur. Le chiffrement par module en donne la garantie entre modules (pas de clé, pas de lecture) ; à l'intérieur d'un module, le cloisonnement entre services repose sur l'interface : un agent du module disposant de compétences techniques pourrait lire les données d'un autre service du même module, sans pouvoir effacer la trace de ses saisies.
- La perte simultanée de tous les moyens de déverrouillage rend les données irrécupérables : c'est la contrepartie d'un chiffrement effectif.
- **Suivi médical** : seules les dates des entretiens et des contrats de soins sont gardées ; les absences des médecins peuvent porter un motif (à limiter à « congé », « formation »… : pas de motif médical) ; les tableaux imprimés portent la mention de confidentialité.
- **Vue d'ensemble et données ajoutées** : chaque donnée ajoutée est à inscrire au registre (traitement 6) avant usage ; rappel « aucune donnée clinique » à la création (mots évocateurs signalés) et sur la saisie des notes ; les **instantanés** sont des copies datées des valeurs affichées, chiffrées par la clé de chaque donnée (une part par journal), à conserver selon la durée réglée ; une donnée protégée « par l'écran » reste lisible par un agent du module techniquement compétent, la protection par **clé propre** l'en empêche (à privilégier pour une donnée sensible).
- **Véhicules** : la consigne « motif court, aucune donnée clinique » figure sur l'écran de réservation ; l'historique des réservations rattache un agent à un déplacement (à prendre en compte pour la

durée de conservation).

- **Agenda** : le réglage de la désignation des patients (initiales par défaut) est un choix de minimisation à valider, en tenant compte des écrans visibles par l'équipe. Les alertes et commentaires sont des informations d'organisation ; la consigne de n'y écrire aucune donnée clinique figure sur chaque écran de saisie.
- **Registre légal** (traitement 2) : il désigne le patient par son IPP et son âge, comme l'exige l'article L. 3222-5-1, et n'est présenté qu'aux instances prévues par la loi. Pour une demande de communication (CADA), l'outil produit une version occultée, choix les plus protecteurs présélectionnés (Conseil d'État, 8 février 2023, n° 455887), édition tracée.
- **Import de la liste du DPI** : le fichier exporté est lu sur le poste ; il reste à la charge de l'agent de le supprimer de son poste après l'import (consigne à inscrire dans la procédure).
- **Copies des données hors du partage principal** (facultatives) : dossier de secours sur un second serveur, copie locale sur des postes désignés (document 10). Ces copies restent chiffrées ; une copie locale emporte toutefois les données chiffrées si le poste est volé : disque chiffré (BitLocker), liste nominative des postes, suppression de la copie à la réforme du poste.

## 3. Mode formation

Le jeu de formation ne contient que des données fictives générées par l'application (noms marqués « fictif »). Il est chiffré séparément. La consigne de ne jamais y saisir de donnée réelle figure dans le bandeau affiché en permanence ; l'administrateur peut régénérer le jeu à tout moment et retirer l'accès au mode formation compte par compte.

## 4. Information des personnes

Les patients sont informés par les moyens habituels de l'établissement (livret d'accueil, affichage, politique de confidentialité), en mentionnant chaque traitement mis en œuvre, ses finalités et les modalités d'exercice des droits. Les agents sont informés du traitement de leurs données (traçabilité des saisies, absences dans l'agenda) par les voies habituelles (note de service, instances du personnel).

---

*Sources : CNIL, liste des types d'opérations de traitement pour lesquelles une AIPD est requise ; article L. 3222-5-1 du code de la santé publique.*

**Données complémentaires de la fiche patient** (version 0.13.0) : l'administrateur peut ajouter des données propres à l'établissement ou à un service (ex. sorties libres, éducateur référent). Chaque donnée ajoutée complète la fiche du registre des traitements « fiche patient » (finalité, catégorie de données, destinataires : rôles qui la voient) et est soumise à l'avis du délégué à la protection des données (DPO, référent RGPD) ; aucune donnée clinique.